

Manual 18 — Implementação controlada da GLBA / Regra de Salvaguardas da FTC

Edição controlada pt-BR — rascunho de localização

****Ordem da série:** 18**

****Limite regulatório:**** Esta edição é orientação de implementação. Não reproduz texto regulatório protegido, não constitui aconselhamento jurídico e não amplia a jurisdição da FTC além das organizações sujeitas à Regra de Salvaguardas. As camadas estatutária, regulatória, de orientação oficial e de prática organizacional devem permanecer distintas.

1. Propósito, escopo e camadas regulatórias

Estabelecer um programa repetível para implementar e evidenciar salvaguardas para informações de clientes abrangidas. Manter um mapa de fontes que diferencie o contexto estatutário da GLBA, os requisitos de 16 CFR Parte 314, emendas e datas de vigência da FTC, orientação oficial da FTC e decisões internas de controle. Evidência: memorando de aplicabilidade, registro de fontes, inventário de controles e confirmação anual de escopo. Teste: verificar rastreabilidade de cada afirmação regulatória substantiva à camada correta.

2. Aplicabilidade a instituições financeiras e jurisdição

Determinar se a organização é instituição financeira para fins da Regra de Salvaguardas da FTC e se outro regulador da GLBA governa a atividade. Documentar atividades, isenções, regulador responsável, limites de entidade e gatilhos de revisão jurídica. Evidência: análise de aplicabilidade e matriz de reguladores. Reavaliar após fusões, novos produtos, mudanças de licença ou nova orientação regulatória.

3. Escopo de informações de clientes e inventário de dados

Inventariar informações de clientes e sistemas que as coletam, processam, transmitem ou armazenam. Mapear fluxos, repositórios, interfaces, backups, endpoints, serviços SaaS e terceiros. Atribuir proprietários e classes de retenção. Evidência: inventário de dados, diagramas de fluxo, registro de sistemas e vínculo com registros de tratamento. Testar completude contra ferramentas de descoberta, contratos e inventários de arquitetura.

4. Governança e responsabilidade do indivíduo qualificado

Designar o indivíduo qualificado responsável e definir autoridade, escalonamento, substitutos, orçamento, deveres de reporte e interfaces com privacidade, jurídico, auditoria, risco e tecnologia. Evidência: charter, descrição de função, RACI e atas. Testar se a autoridade atribuída é operacional e não meramente nominal.

5. Programa escrito de segurança da informação

Manter um programa escrito proporcional ao porte, complexidade, atividades e sensibilidade das informações de clientes. Conectar governança, avaliação de riscos, salvaguardas, monitoramento, resposta a incidentes, supervisão de prestadores e reporte. Evidência:

programa aprovado, histórico de revisão, padrões vinculados e proprietários de controles. Revisar ao menos anualmente e após mudança material.

6. Metodologia de avaliação de riscos

Usar metodologia documentada para identificar riscos internos e externos previsíveis, avaliar probabilidade e impacto e determinar se as salvaguardas existentes são suficientes. Definir pontuação, critérios de aceitação, evidências e gatilhos de reavaliação. Evidência: metodologia, registro de riscos e decisões de tratamento. Testar repetibilidade comparando sistemas semelhantes.

7. Tratamento de riscos e seleção de salvaguardas

Converter achados de risco em salvaguardas preventivas, detectivas, corretivas e de recuperação. Registrar objetivo, proprietário, estado, fonte de evidência, risco residual, data-alvo e tratamento de exceções. Evidência: plano de tratamento e matriz de controles. Testar se riscos significativos têm tratamento explícito ou aceitação formal.

8. Inventário de ativos e sistemas

Manter inventários autoritativos de hardware, software, ativos virtuais, serviços em nuvem, aplicações críticas, componentes de rede e repositórios no escopo. Incluir proprietário, ambiente, criticidade, estado de ciclo de vida e relevância para informações de clientes. Evidência: reconciliação CMDB/inventário. Testar ativos órfãos ou não gerenciados.

9. Classificação e tratamento de dados

Definir requisitos de tratamento de informações de clientes em coleta, uso, armazenamento, transmissão, compartilhamento, arquivamento e destruição. Alinhar classificação com acesso, criptografia, mascaramento, DLP e retenção. Evidência: padrão de classificação, conjuntos rotulados e procedimentos. Testar repositórios e transferências de amostra.

10. Gestão de identidades e acessos

Aplicar privilégio mínimo, acesso baseado em papéis ou atributos, provisionamento e desprovisionamento oportunos, revisões periódicas e controles sólidos de admissão-mudança-desligamento. Evidência: solicitações, aprovações, revisões e registros de desligamento. Testar contas inativas, excessivas, compartilhadas ou não autorizadas.

11. Acesso privilegiado e autenticação

Restringir e monitorar identidades privilegiadas. Usar autenticação forte apropriada ao ambiente, incluindo MFA quando exigida ou justificada por risco. Separar contas administrativas e padrão. Evidência: logs de PAM, inventário privilegiado, cobertura MFA e registros break-glass. Testar caminhos privilegiados e revisão de acesso emergencial.

12. Criptografia e gestão de chaves

Proteger informações de clientes em trânsito e repouso com controles criptográficos apropriados ou proteção compensatória formalmente documentada quando permitida e justificada. Gerenciar geração, armazenamento, rotação, revogação, backup, acesso e destruição de chaves. Evidência: configurações, inventário de chaves e exceções. Testar endpoints, bancos de dados, backups e interfaces representativas.

13. Configuração segura e controle de mudanças

Estabelecer baselines seguras, responsáveis por configuração, fluxos de aprovação, segregação de funções, rollback e revisão de mudanças emergenciais. Evidência: padrões, varreduras, tickets e aprovações. Testar drift e mudanças não autorizadas.

14. Gestão de vulnerabilidades

Identificar, priorizar, remediar e verificar vulnerabilidades segundo risco. Definir cobertura de varredura, varredura autenticada, relação severidade-SLA, critérios de exceção e escalonamento. Evidência: relatórios, tickets e exceções. Testar vulnerabilidades vencidas e padrões recorrentes.

15. Desenvolvimento seguro e controles de aplicação

Integrar segurança em requisitos, projeto, desenvolvimento, testes, implantação e manutenção de aplicações que tratam informações de clientes. Incluir revisão de código, dependências, segredos, modelagem de ameaças, testes de segurança e aprovação de release. Evidência: registros SDLC, SAST/DAST, relatórios de dependências e gates de liberação.

16. Logging, monitoramento e detecção de anomalias

Coletar e proteger logs necessários para detectar acesso não autorizado, uso indevido, atividade anômala, falhas de controle e incidentes. Definir sincronização de tempo, retenção, responsáveis por alertas, escalonamento e tuning de casos de uso. Evidência: padrão de logging, cobertura SIEM, alertas e configurações de retenção. Testar detecção ponta a ponta.

17. Resposta a incidentes e escalonamento

Manter procedimentos de identificação, triagem, contenção, erradicação, recuperação, preservação de evidências, comunicações e melhoria pós-incidente. Atribuir responsabilidade pelas decisões de notificação jurídica e regulatória. Evidência: plano, exercícios, registros e lições aprendidas. Testar com tabletop envolvendo comprometimento de informações de clientes.

18. Fluxo de decisão para eventos de notificação à FTC

Manter fluxo documentado para eventos potencialmente enquadrados no limite de notificação da Regra de Salvaguardas. Preservar o limite atualmente verificado: análise de aquisição sem autorização de informações de clientes não criptografadas, limiar aplicável de pelo menos 500 consumidores e requisito atualmente verificado de notificação em no máximo 30 dias. Não generalizar essas condições fora do contexto da regra da FTC. Evidência: planilha de decisão, revisão jurídica, base da contagem de consumidores e registro de notificação. Revalidar o texto regulatório vigente antes da liberação e em cada incidente relevante.

19. Interfaces com continuidade e resiliência

Identificar dependências entre salvaguardas e continuidade, incluindo identidade, logging, gestão de chaves, backups seguros, comunicações alternativas e sequência de

recuperação. Evidência: vínculo com BIA, planos e exercícios. Testar que a recuperação não ignore controles de segurança sem autorização emergencial documentada.

20. Due diligence de prestadores de serviço

Avaliar prestadores que recebam, mantenham, processem ou acessem informações de clientes. Examinar capacidade de segurança, evidência de controles, incidentes, resiliência, subcontratação e concentração. Evidência: pacote de due diligence, classificação de risco, aprovações e compromissos de remediação.

21. Salvaguardas contratuais e supervisão

Usar cláusulas contratuais apropriadas para exigir salvaguardas e permitir supervisão. Rastrear obrigações de segurança, termos de notificação de incidentes, direitos de auditoria/evidência, devolução ou destruição de dados e requisitos de subcontratados. Evidência: contratos, registro de obrigações e calendário de revisão. Testar prestadores selecionados contra obrigações vigentes.

22. Nuvem e responsabilidade compartilhada

Mapear salvaguardas entre responsabilidades do provedor e do cliente em IaaS, PaaS e SaaS. Documentar identidade, logging, criptografia, configuração, backup, rede e incidentes. Evidência: matriz de responsabilidade compartilhada, configuração de nuvem e assurance do provedor. Testar lacunas criadas por pressupostos incorretos.

23. Segurança da força de trabalho e treinamento

Implementar conscientização e treinamento especializado por função para administradores, desenvolvedores, respondedores, gestores de fornecedores e outros papéis de alto risco. Evidência: currículo, registros de conclusão, mapeamento de funções e exercícios. Testar cobertura e efetividade com métricas adequadas.

24. Salvaguardas físicas

Proteger instalações, dispositivos, mídias e áreas restritas por controles de acesso, visitantes, ambiente, armazenamento seguro e descarte proporcional ao risco. Evidência: logs, registros de visitantes, avaliações e manuseio de mídia. Testar revogação de acesso e controles de áreas restritas.

25. Retenção e descarte seguro de dados

Definir períodos de retenção com base em requisitos jurídicos, regulatórios, contratuais, operacionais e de risco; eliminar informações de clientes quando não forem mais necessárias. Evidência: tabela de retenção, rotinas de exclusão, certificados de destruição e exceções de legal hold. Testar retenção excessiva e conclusão de descarte.

26. Testes de controles e monitoramento contínuo

Estabelecer programa de testes por revisão de evidências, validação técnica, amostragem, autoavaliação, testes independentes quando apropriados e monitoramento contínuo. Evidência: planos, papéis de trabalho, achados e métricas. Ajustar frequência conforme criticidade e taxa de mudança.

27. Governança de testes de penetração e avaliação de vulnerabilidades

Definir governança para testes de penetração e avaliações de vulnerabilidade conforme a Regra de Salvaguardas vigente e o risco organizacional. Especificar escopo, independência/competência, acompanhamento de remediação, reteste e exceções.

Evidência: relatórios, planos e retestes. Revalidar os requisitos atuais da FTC antes da liberação.

28. Reporte à gestão e ao órgão de governança

Reportar periodicamente postura de risco, deficiências materiais, incidentes, riscos de prestadores, remediação, testes e mudanças do programa à governança apropriada.

Evidência: relatórios, atas e registros de ações. Testar se questões materiais são escaladas e acompanhadas até o encerramento.

29. Exceções, aceitação de risco e remediação

Usar processo controlado que registre justificativa, salvaguardas compensatórias, risco residual, aprovador responsável, expiração e plano de remediação. Evidência: registro e aprovações. Testar exceções expiradas e extensões repetidas sem reavaliação.

30. Arquitetura de evidências e preparação para auditoria

Definir objetos de evidência por salvaguarda, convenções, repositórios, retenção, cadeia de custódia quando aplicável e responsáveis. Manter mapeamentos evidência-controle e distinguir evidência operacional de afirmação gerencial. Evidência: catálogo, matriz e papéis de trabalho. Testar reconstrução independente de controles amostrados.

31. Gatilhos de mudança, monitoramento de emendas e reavaliação

Monitorar emendas da FTC, orientação oficial, desenvolvimentos de enforcement relevantes e mudanças organizacionais que afetem aplicabilidade ou salvaguardas. Acionar reavaliação após mudanças materiais em tecnologia, dados, prestadores, produtos, modelo de negócio ou regulação. Evidência: registro de monitoramento e avaliações de mudança.

32. Localização, QA de artefatos e controles de liberação

Congelar a fonte inglesa exata antes da localização controlada es-419 e pt-BR. Vincular cada localização à identidade inglesa congelada e preservar o significado regulatório sem apresentar traduções não oficiais como texto autoritativo da FTC. Antes da publicação exigir paridade trilingue, QA de renderização/páginas, acessibilidade, hashes SHA-256 exatos, staging durável, segurança de workflows, reverificação de fontes, publicação do predecessor e reconciliação do catálogo/registro de releases.

Limite controlado de liberação

Este rascunho localizado não estabelece por si só conformidade, interpretação jurídica, assurance de auditoria nem elegibilidade de publicação. Qualquer requisito documentado de revisão humana genuína permanece aberto até ser vinculado aos hashes exatos aplicáveis.